

CompTIA Security+ SY0-701

Practice Quiz Set

Tiered Multiple-Choice & PBQ Simulations — with Full Answer Key

30 original questions distributed by the official domain weightings and cognitive tiers. Questions are the companion to the Detailed Domain Notes — every answer explains the causal reason it is correct and why each distractor is wrong.

Domain	Weight	Questions
4 — Security Operations	28%	8 (incl. 3 PBQ)
2 — Threats, Vulnerabilities & Mitigations	22%	7 (incl. 1 PBQ)
5 — Program Management & Oversight	20%	6
3 — Security Architecture	18%	5 (incl. 1 PBQ)
1 — General Security Concepts	12%	4
Total	100%	30

How to use: Work a domain block, then check the answer key at the end. Multiple-response questions state how many to pick. For PBQs, reason through the steps before revealing the key — the key shows the reasoning, not just the letter. Passing the real exam takes 750/900 in up to 90 questions / 90 minutes.

Domain 1 — General Security Concepts

Q1. [1.1] · Recall

A company posts a sign reading "Warning: this area is under 24-hour video surveillance." Which control **type** does the sign itself represent?

- A. Detective
- B. Corrective
- C. Deterrent
- D. Compensating

Q2. [1.2] · Application

An administrator authenticated 45 minutes ago now requests a sensitive database. The system re-checks device posture and risk before allowing it. Which model is in use, and which component makes the decision?

- A. Perimeter model; the firewall
- B. Zero trust; the policy engine (control plane)
- C. Zero trust; the policy enforcement point (data plane)
- D. Discretionary access control; the data owner

Q3. [1.4] · Application

Which single mechanism provides integrity, authentication, AND non-repudiation together?

- A. Symmetric encryption
- B. Hashing alone
- C. A digital signature
- D. Salting

Q4. [1.1] · Recall

A legacy application cannot be patched. The team adds MFA and enhanced monitoring around it instead. What kind of control are MFA and monitoring acting as here?

- A. Directive
- B. Compensating
- C. Preventive only
- D. Deterrent

Domain 2 — Threats, Vulnerabilities & Mitigations

Q5. [2.1] · Application

Over several weeks, one executive receives slow, highly targeted login attempts from constantly changing infrastructure, with no noisy scanning. Which threat actor best fits, and what is the priority response?

- A. Unskilled attacker; apply the latest patch
- B. Hacktivist; issue a public statement
- C. Nation-state/APT; enhance monitoring and threat hunting
- D. Insider; revoke the executive's badge

Q6. [2.2] · Application

Finance receives an urgent email appearing to come from the CFO requesting an immediate wire transfer. SPF, DKIM, and the mail filter all pass. What is the most effective mitigation?

- A. Add another spam filter rule
- B. Out-of-band verification and dual-approval for wires
- C. Force a company-wide password reset
- D. Block all external email

Q7. [2.3] · Analysis

A developer concatenates user input directly into a database query. Which vulnerability class results, and what is the correct fix?

- A. Cross-site scripting; output encoding
- B. Buffer overflow; ASLR
- C. SQL injection; parameterized queries
- D. Race condition; file locking

Q8. [2.4] · Analysis

An authentication log shows exactly one failed login for each of 200 different accounts within 60 seconds, all from the same source IP. Which attack is this, and why is simple account lockout insufficient?

- A. Brute force; lockout works fine
- B. Password spraying; it stays under per-account lockout thresholds
- C. Credential stuffing; the passwords were breached
- D. DDoS; it floods the auth server

Q9. [2.5] · Application

Ransomware has encrypted files on one workstation. Which control most directly limits it from spreading to other network zones?

- A. Full-disk encryption
- B. Network segmentation
- C. A longer password policy
- D. A warning banner

Q10. [2.2] · Recall

Match the social-engineering technique to its vector. Which pairing is correct?

- A. Smishing → voice call
- B. Vishing → SMS text
- C. Watering hole → a compromised site the target group visits
- D. Pretexting → removable media

Q11. [2.4] · Analysis · PBQ — Log Analysis

Review the excerpt below and identify what happened. Select the **single best** description.

```
02:14:07 FW ALLOW 203.0.113.9 -> 10.0.0.20:443 (WebServer)
02:14:09 WEB POST /upload.php 200 payload=""
02:15:41 AUTH new local admin "svc_help" created on 10.0.0.20
02:16:03 EDR new service "wmiprv32" set to auto-start on 10.0.0.20
02:17:22 FW ALLOW 10.0.0.20 -> 198.51.100.5:8443 (outbound, 2.3 GB)
```

- A. A volumetric DDoS attack against the web server
- B. Web-app exploit (webshell upload) → privilege escalation → persistence → data exfiltration
- C. A password-spraying attack that failed
- D. Normal patch-management activity

Domain 3 — Security Architecture

Q12. [3.1] · Analysis

A company using a SaaS CRM suffers a data leak caused by a misconfigured record-sharing setting. Under the shared responsibility model, who is responsible?

- A. The SaaS provider — they run the platform
- B. The customer — configuration and access are always theirs

- C. Neither; SaaS has no customer responsibility
- D. The provider, because it is their infrastructure

Q13. [3.3] · Analysis

A merchant wants to remove card numbers from its application database entirely to shrink PCI audit scope. Which technique fits best, and why does it beat encryption here?

- A. Hashing; it is one-way
- B. Encryption; the data stays protected
- C. Tokenization; the real value never resides in the app, so a DB breach yields useless tokens
- D. Masking; it hides part of the value

Q14. [3.4] · Application

A trading platform tolerates up to 5 minutes of downtime but zero data loss. Which pairing meets both objectives?

- A. Cold site + nightly backups
- B. Hot site + synchronous replication
- C. Warm site + weekly backups
- D. Single server + daily backups

Q15. [3.2] · Application

Where should an IDS be placed if the requirement is to monitor internal traffic for anomalies **without** adding latency or risking dropped packets?

- A. Inline in the main traffic path
- B. Out-of-band on a mirror/SPAN port
- C. On each endpoint as the only sensor
- D. In front of the firewall as a proxy

Q16. [3.2] · Analysis · PBQ — Device Placement

A topology has: the internet, an edge router, a screened subnet (DMZ) hosting a public web server, and an internal LAN with sensitive databases. Administrators must reach internal servers only through one audited, controlled path. Which placement set is correct? (Choose the **single best** layout.)

- A. Put the databases in the DMZ and the web server on the internal LAN
- B. Place a firewall at the edge and between DMZ and LAN; put the public web server in the DMZ; require admins to use a jump server in a management segment to reach internal servers
- C. Expose the databases directly to the internet behind only the edge router
- D. Place an IPS on a SPAN port and remove the internal firewall

Domain 4 — Security Operations

Q17. [4.6] · Analysis

An account protected by a strong password is compromised via phishing. Which change most effectively prevents a repeat, and why?

- A. Require a second password/PIN — more knowledge factors
- B. Add a possession or FIDO2 factor — it crosses factor categories and resists phishing
- C. Increase password length to 20 characters
- D. Rotate the password every 30 days

Q18. [4.3] · Analysis

A scan returns two findings: CVE-X (CVSS 10.0) on an air-gapped test box with no known exploit, and CVE-Y (CVSS 7.5) on an internet-facing server being actively exploited in the wild. Which should be remediated first, and why?

- A. CVE-X — always patch the highest CVSS first
- B. CVE-Y — exposure and active exploitation outweigh raw severity
- C. Neither until the next maintenance window
- D. Both are equal; pick either

Q19. [4.4] · Application

Which tool should you deploy to block a spreadsheet full of Social Security numbers from being emailed outside the organization?

- A. SIEM
- B. NetFlow
- C. DLP
- D. SNMP trap

Q20. [4.7] · Analysis

A team automates user provisioning so the HR system creates accounts with role-based access on hire. What is the primary **risk** introduced by this automation?

- A. It eliminates orphaned accounts
- B. A flawed role mapping is applied to every new hire instantly, and the pipeline is a single point of failure
- C. It is slower than manual provisioning
- D. It removes the need for least privilege

Q21. [4.8] · Analysis

During ransomware response, a technician wants to immediately re-image the infected servers to restore service. Why is this premature, and what must happen first?

- A. Nothing — re-imaging first is correct
- B. Containment and forensic capture must precede eradication/recovery; re-imaging destroys evidence and may leave the attacker's channel open
- C. You must first pay the ransom
- D. Recovery always comes before containment

Q22. [4.5] · Application

A company has SPF and DKIM published, yet attackers still successfully spoof its domain. The DMARC record is set to p=none. What single change fixes this?

- A. Remove SPF
- B. Set DMARC to p=quarantine or p=reject
- C. Disable DKIM
- D. Publish a second SPF record

Q23. [4.5] · Analysis · PBQ — Firewall Rule Ordering

The goal is to permit HTTPS from anywhere to WebServer (10.0.0.20) while blocking all other traffic to its subnet 10.0.0.0/24. The current rule set (evaluated top-down, first match wins) is:

```
Rule 1: DENY ip any -> 10.0.0.0/24
Rule 2: PERMIT tcp any -> 10.0.0.20 : 443
Rule 3: (implicit DENY ALL)
```

Users report HTTPS to the web server is being blocked. What is wrong and how do you fix it?

- A. Rule 2 is too broad; delete it
- B. Rule 1 (broad deny) matches first and stops evaluation before Rule 2; move the specific PERMIT (Rule 2) above the DENY
- C. Add a second implicit deny at the top
- D. The 443 port is wrong; change it to 80

Q24. [4.4] · Application · PBQ — Tool/Purpose Matching (choose THREE)

Select the **THREE** correct tool-to-purpose pairings.

- A. SIEM → correlate authentication failures with a later privileged action across sources
- B. NetFlow → identify an internal host beaconing large volumes outbound
- C. Antivirus → distribute network IP addresses to clients
- D. SNMP trap → alert when a router interface goes down
- E. DLP → route email between mail servers

Q25. [4.9] · Analysis · PBQ — Investigation

While reconstructing an intrusion you notice the firewall, web, and endpoint logs disagree on event times by several minutes, making the sequence impossible to order reliably. What is the root cause and the fix?

- A. The logs are forged; discard them
- B. Clocks are not synchronized; deploy NTP so timestamps align across sources
- C. The SIEM is broken; reinstall it
- D. Time zones don't matter for forensics; ignore the gaps

Q26. [4.1] · Application

Why does WPA3 resist offline dictionary attacks on the wireless handshake better than WPA2?

- A. It uses a longer SSID
- B. It uses Simultaneous Authentication of Equals (SAE) instead of the WPA2 4-way handshake
- C. It disables encryption
- D. It broadcasts the passphrase

Domain 5 — Security Program Management & Oversight

Q27. [5.2] · Analysis

An asset is valued at \$200,000. A fire would destroy 50% of it, and fires are expected once every 4 years. What is the Annualized Loss Expectancy (ALE)?

- A. \$100,000
- B. \$50,000
- C. \$25,000
- D. \$400,000

Q28. [5.2] · Application

Following Q27, a mitigation costs \$30,000 per year and would eliminate the fire risk. Based on ALE alone, is it justified?

- A. Yes — always buy controls for high-value assets
- B. No — the \$30,000 annual cost exceeds the \$25,000 ALE it removes
- C. Yes — it reduces the SLE
- D. There is not enough information

Q29. [5.1] · Recall

A hospital decides how and why patient data is processed; a cloud vendor processes it strictly on the hospital's instructions. Which roles do they hold?

- A. Hospital = processor; vendor = controller
- B. Hospital = controller; vendor = processor
- C. Both are controllers
- D. Both are custodians

Q30. [5.5] · Analysis

A regulator requires an objective evaluation of your controls, and separately your team wants to test whether the SOC can detect a novel, unknown intrusion. Which two engagements fit?

- A.** Internal audit for the regulator; white-box test for detection
- B.** External audit for the regulator; black-box (unknown-environment) pen test for detection
- C.** Self-attestation for both
- D.** White-box test for the regulator; internal audit for detection

Answer Key & Explanations

Each entry gives the correct answer, the causal reason it is right, and why the distractors are wrong. PBQ entries include the reasoning steps.

Q1 [1.1] · Recall Correct: C

Why: The sign discourages an attacker from acting — that is the definition of a deterrent control. The camera it refers to may be detective, but the sign's function is to deter.

Distractors: A: the camera detects; the sign does not. B: corrective restores after an event. D: compensating substitutes for an infeasible primary control.

Q2 [1.2] · Application Correct: B

Why: Re-verifying every request regardless of prior authentication is zero trust; the policy engine in the control plane makes the trust decision.

Distractors: C: the enforcement point (data plane) acts on the decision, it doesn't make it. A: the perimeter model would trust an already-inside session. D: DAC is an access-control model, not this re-evaluation behavior.

Q3 [1.4] · Application Correct: C

Why: A digital signature hashes the message (integrity) and encrypts the hash with the sender's private key — only that sender could produce it (authentication + non-repudiation).

Distractors: A: symmetric encryption gives confidentiality, and its shared key can't prove who sent it. B: hashing gives integrity only. D: salting only strengthens stored hashes.

Q4 [1.1] · Recall Correct: B

Why: When the primary control (patching) is infeasible, an alternate control that provides comparable protection is a compensating control.

Distractors: A: directive instructs behavior via policy. C: "preventive only" ignores the compensating role and monitoring is detective. D: deterrent discourages; these actively protect.

Q5 [2.1] · Application Correct: C

Why: Patience, targeting, resources, and low noise indicate an APT. Because they can burn zero-days and wait, the proportionate response is detection depth and threat hunting, not a single patch.

Distractors: A: unskilled actors are noisy and use known exploits. B: hackers seek publicity, not stealth. D: nothing indicates an insider; the vector is external.

Q6 [2.2] · Application Correct: B

Why: This is business email compromise — the exploit is human trust, not code, and technical checks can pass on a look-alike or spoofed display. A procedural control (verify via a known channel + dual approval) defeats it.

Distractors: A: filters already passed; more rules won't catch social engineering. C: no credentials were necessarily stolen. D: blocking all external email is infeasible and disproportionate.

Q7 [2.3] · Analysis Correct: C

Why: Untrusted input executed by the database engine is SQL injection. Parameterized (prepared) statements separate code from data so input can never alter the query structure.

Distractors: A: XSS executes in the browser, not the DB; encoding fixes XSS not SQLi. B/D: wrong vulnerability classes entirely for this cause.

Q8 [2.4] · Analysis Correct: B

Why: One attempt spread across many accounts is password spraying — deliberately designed to avoid tripping per-account lockout. MFA and anomalous-login detection are the effective controls.

Distractors: A: brute force hammers one account with many attempts. C: stuffing uses known username/password pairs (still needs MFA, but the pattern here is one-per-account spraying). D: DDoS targets availability, not credential guessing.

Q9 [2.5] · Application Correct: B

Why: Segmentation contains lateral movement by isolating zones, so an infection in one VLAN cannot reach others — directly limiting blast radius.

Distractors: A: encryption protects confidentiality, not spread. C/D: password length and banners don't contain propagation.

Q10 [2.2] · Recall Correct: C

Why: A watering-hole attack compromises a website the target population frequents, infecting them when they visit.

Distractors: A: smishing is SMS-based. B: vishing is voice-based. D: pretexting is a fabricated scenario, not a media vector.

Q11 [2.4] · Analysis · PBQ Correct: B

Why: Read the timeline in order: an allowed inbound HTTPS connection, a POST uploading PHP that runs system commands (webshell), then a new admin account (privilege escalation), an auto-start service (persistence), and a large outbound transfer (exfiltration). The mitigation targets the entry point — patch/validate the upload function — not just deleting the service.

Distractors: A: a single connection isn't volumetric DDoS. C: no repeated auth failures appear. D: unauthorized admin creation and a 2.3 GB outbound transfer are not patch activity.

Q12 [3.1] · Analysis Correct: B

Why: Even in SaaS, the customer always owns data classification, access, and configuration. A sharing misconfiguration is a customer responsibility; the provider's infrastructure was not breached.

Distractors: A/D: the provider secures the platform, not your configuration choices. C: customers always retain data/access/config duties.

Q13 [3.3] · Analysis Correct: C

Why: Tokenization replaces the PAN with a random surrogate stored elsewhere, so the sensitive value never lives in the app database — removing it from scope. Encryption keeps the (scrambled) data present, so scope remains.

Distractors: A: hashing is irreversible; you can't process payments from a hash. B: encryption keeps data in place, not reducing scope. D: masking is a display control, not a storage-scope reducer.

Q14 [3.4] · Application Correct: B

Why: Zero data loss means RPO≈0 → synchronous replication. Near-zero downtime means low RTO → a hot site. The two metrics require two different investments.

Distractors: A/C/D: nightly/weekly/daily backups all permit hours-to-days of data loss (bad RPO), and cold/warm/single fail the 5-minute RTO.

Q15 [3.2] · Application Correct: B

Why: An IDS only needs a copy of traffic to analyze, so a SPAN/mirror port lets it observe without sitting in the path — no latency, no dropped-packet risk. (An IPS, which must block, goes inline.)

Distractors: A: inline placement is for an IPS that must drop traffic and adds a failure point. C: endpoints miss network-wide patterns. D: a proxy mediates traffic, not passive anomaly monitoring.

Q16 [3.2] · Analysis · PBQ Correct: B

Why: Public-facing services belong in the DMZ, isolated by firewalls on both sides so a compromised web server can't directly reach the sensitive LAN. A jump server in a management segment gives administrators the single, audited entry point to internal servers. Each element maps to its function.

Distractors: A: databases must never sit in the DMZ, and the web server must be reachable publicly. C: exposing databases to the internet is the opposite of segmentation. D: an IPS on a SPAN port can't block (SPAN is passive), and removing the internal firewall destroys the DMZ/LAN boundary.

Q17 [4.6] · Analysis Correct: B

Why: Real MFA requires factors from independent categories. A possession/FIDO2 factor can't be phished like a password, and FIDO2/passkeys bind to the site origin so they can't be replayed on a fake page.

Distractors: A: a second knowledge factor is still phishable — same failure mode. C/D: length and rotation don't stop a user handing the password to a phishing site.

Q18 [4.3] · Analysis Correct: B

Why: Prioritization combines severity with exposure and exploit likelihood. An internet-facing, actively exploited 7.5 poses greater real risk than an unreachable 10.0 with no exploit.

Distractors: A: patching by raw CVSS ignores context and is the classic wrong answer. C: an actively exploited external flaw can't wait. D: the risk contexts are clearly unequal.

Q19 [4.4] · Application Correct: C

Why: Data Loss Prevention inspects content and blocks sensitive data (like SSNs) from leaving via email, USB, or cloud channels.

Distractors: A: a SIEM correlates logs, it doesn't block egress. B: NetFlow shows traffic volume/metadata, not content. D: SNMP traps report device state changes.

Q20 [4.7] · Analysis Correct: B

Why: Automation's leverage cuts both ways: a bug in the workflow propagates everywhere at once, and the pipeline itself becomes a single point of failure — so it needs the same change control and testing as production code.

Distractors: A: that's a benefit, not a risk. C: automation is faster, not slower. D: least privilege still applies — the role mapping must enforce it.

Q21 [4.8] · Analysis Correct: B

Why: The lifecycle order is causal: contain (cut the attacker's access) and capture forensic evidence before eradicating/recovering. Re-imaging first destroys chain-of-custody evidence and can restore into a still-open compromise.

Distractors: A: skips containment and forensics. C: paying is never a required IR step. D: containment precedes recovery, not the reverse.

Q22 [4.5] · Application Correct: B

Why: p=none only monitors — failing mail is still delivered. Moving DMARC to quarantine or reject tells receivers to actually stop mail that fails SPF/DKIM alignment, closing the spoofing gap.

Distractors: A/C: removing SPF or DKIM weakens authentication. D: publishing two SPF records is invalid and breaks SPF entirely.

Q23 [4.5] · Analysis · PBQ Correct: B

Why: Because the firewall acts on the first match, the broad "deny all to the subnet" (Rule 1) matches HTTPS traffic first and evaluation stops — the permit never runs. Reorder so the specific PERMIT tcp/443 sits above the broad DENY. Specific rules must precede general ones.

Distractors: A: Rule 2 is the rule you need; deleting it blocks HTTPS entirely. C: a deny at the top blocks everything. D: HTTPS is port 443; changing to 80 breaks the requirement.

Q24 [4.4] · Application · PBQ Correct: A, B, D

Why: A: cross-source correlation is exactly the SIEM's job. B: NetFlow exposes traffic volume/patterns, ideal for spotting large outbound beaconing. D: SNMP traps are device-initiated alerts on state changes like an interface going down.

Distractors: C: distributing IPs is DHCP, not antivirus. E: routing mail between servers is an MTA function, not DLP (which inspects/blocks sensitive content).

Q25 [4.9] · Analysis · PBQ Correct: B

Why: A reliable timeline depends on synchronized clocks. Without NTP, independent sources drift and the causal order of events becomes unreadable. Synchronizing time (NTP) aligns timestamps so the chain can be reconstructed.

Distractions: A: disagreement from drift isn't evidence of forgery. C: the SIEM ingests what it's given; the source clocks are the problem. D: accurate, synchronized time is foundational to forensics.

Q26 [4.1] · Application Correct: B

Why: WPA3's SAE (dragonfly) handshake does not expose a hash an attacker can capture and crack offline, unlike WPA2's 4-way handshake — so a captured exchange can't be brute-forced at leisure.

Distractions: A: SSID length is irrelevant to handshake security. C/D: WPA3 strengthens, not disables, encryption and never broadcasts secrets.

Q27 [5.2] · Analysis Correct: C

Why: $SLE = AV \times EF = \$200,000 \times 0.50 = \$100,000$. $ARO = 1/4 = 0.25$. $ALE = SLE \times ARO = \$100,000 \times 0.25 = \$25,000/yr$.

Distractions: A: that's the SLE, not annualized. B: miscalculates ARO as 0.5. D: multiplies instead of applying the exposure factor and rate correctly.

Q28 [5.2] · Application Correct: B

Why: A control is economically justified only when it reduces ALE by more than it costs. \$30,000/yr to remove \$25,000/yr of risk is a net loss — better to accept the risk or find a cheaper control.

Distractions: A: cost/benefit, not asset value, decides. C: ALE, not SLE, is the annual comparison basis. D: ALE and cost are both given — enough to decide.

Q29 [5.1] · Recall Correct: B

Why: The entity that determines the purpose and means of processing is the data controller (hospital); the entity acting on its instructions is the data processor (vendor). Liability follows the role.

Distractions: A: reverses the roles. C: only the hospital sets purpose/means. D: custodians implement day-to-day controls; that's not what's described.

Q30 [5.5] · Analysis Correct: B

Why: Regulators require external audits for objectivity you cannot provide about your own work. To test detection of an unknown intruder, a black-box (unknown-environment) pen test best simulates a real external attacker.

Distractions: A: an internal audit lacks the independence regulators require; white-box skips reconnaissance so it doesn't test detection. C: self-attestation isn't objective. D: reverses the appropriate methods.

Coverage Check

Domain	Questions	Exam weight
Domain 1	4	12%
Domain 2	7	22%
Domain 3	5	18%
Domain 4	10	28%
Domain 5	4	20%
Total	30	100%

Original practice questions built to the SY0-701 (V7), objectives v5.0 blueprint and CompTIA's authorized-materials policy — no real exam items reproduced. Pair with the Detailed Domain Notes and Causal Architectural Maps.